



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



CVE-2026-35273 Oracle PeopleSoft Enterprise PeopleTools Missing Authentication for Critical Function Vulnerability

CVE / Vulnerability Threat Intelligence Report

Classification	TLP:CLEAR
Published	2026-06-12
Version	1.0
Author	Lost Boys Cyber
Report Type	CVE / Vulnerability Threat Intelligence Report

TLP:CLEAR | Lost Boys Cyber | CVE-2026-35273 Oracle PeopleSoft Enterprise PeopleTools Missing Authentication for Critical Function Vulnerability - CVE / Vulnerability Threat Intelligence Report

Published: 2026-06-12 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Intelligence Requirement
3. Source Review and Confidence
4. Key Findings
5. Threat Context
6. Detection and Hunting
7. Recommendations
8. References

CVE-2026-35273 Oracle PeopleSoft Enterprise PeopleTools Missing Authentication for Critical Function Vulnerability

1. Executive Summary

CVE-2026-35273 is a critical, unauthenticated Oracle PeopleSoft Enterprise PeopleTools vulnerability affecting the Updates Environment Management component in supported PeopleTools 8.61 and 8.62 deployments. Oracle, the CVE Program, and NVD all describe a remotely reachable HTTP attack path that can allow full compromise of the targeted PeopleTools environment, and Oracle rates the issue at CVSS v3.1 9.8. CISA added the flaw to the Known Exploited Vulnerabilities (KEV) catalog on 2026-06-12, making this both a patching emergency and a compromise-assessment priority.

Public reporting from Mandiant / Google Threat Intelligence Group (GTIG) and Rapid7 indicates the vulnerability was exploited as a zero-day before Oracle published its out-of-band alert. Those sources tie the exploitation to activity against Environment Management Hub (PSEMHUB) endpoints and describe follow-on attacker behaviors including deployment of MeshCentral agents, suspicious HTTP POST activity to PeopleSoft endpoints, web-shell style persistence under PSEMHUB paths, and outbound connections to attacker-controlled infrastructure. While some public reporting characterizes the root cause as SSRF-to-RCE, the authoritative vendor/CVE/NVD description should remain the canonical basis for remediation decisions: unauthenticated network access over HTTP can result in takeover of PeopleSoft Enterprise PeopleTools.

For defenders, the highest-risk exposure class is any internet-facing or broadly reachable PeopleSoft deployment running vulnerable PeopleTools versions with Environment Management functionality exposed. Emergency work should focus on four parallel tracks: identify every 8.61/8.62 instance, apply Oracle's out-of-band remediation guidance, disable or isolate Environment Management Hub where feasible, and conduct retrospective hunting for exploitation indicators and follow-on persistence.

Priority Takeaway	Why It Matters
Patch / mitigate immediately	KEV-listed, actively exploited, unauthenticated network path to compromise
Prioritize PSEMHUB exposure	Public reporting aligns exploitation with Environment Management Hub endpoints
Hunt for post-exploitation artifacts	Reported campaigns moved quickly into persistence, remote management, and lateral movement
Preserve logs before cleanup	Access logs, filesystem artifacts, and outbound network telemetry are central to compromise assessment

2. Intelligence Requirement

This report addresses the following intelligence requirement: what CVE-2026-35273 enables, which Oracle PeopleSoft deployments are most exposed, what is known about active exploitation, and which detection, hunting, and remediation steps defenders should prioritize immediately.

Intelligence Question	Assessment
What is the vulnerability?	An unauthenticated, remotely exploitable flaw in Oracle PeopleSoft Enterprise PeopleTools Updates Environment Management that can result in takeover of the application environment.
What is the affected scope?	Public primary sources name PeopleTools 8.61 and 8.62 as affected. Oracle notes PeopleSoft Enterprise Applications customers may also be affected through the vulnerable component.

Is exploitation confirmed?	Yes. CISA added the flaw to KEV on 2026-06-12, and Mandiant / GTIG reported observed exploitation between 2026-05-27 and 2026-06-09.
What environments should be treated as highest risk?	Internet-facing or broadly reachable PeopleSoft / PSEMHUB deployments, especially in higher education and other large multi-instance enterprise estates.
What should defenders do first?	Apply vendor-directed remediation, disable or isolate Environment Management Hub if possible, review web-tier and host artifacts, and hunt for suspicious inbound POST activity and follow-on outbound communications.

3. Source Review and Confidence

The reviewed source set is strong for urgency, affected-version scope, and exploitation status. Oracle's security alert and text-form advisory are the primary sources for the official vulnerability description and affected versions. The CVE Program API and NVD API corroborate the same core facts and add machine-readable metadata such as the CPEs, CVSS vector, KEV addition date, and CISA-required action text.

Confidence is lower for precise root-cause mechanics and full exploitation chain detail because Oracle's public alert is intentionally concise and the patch availability document requires Oracle support access. Secondary reporting from Mandiant / GTIG and Rapid7 materially improves defensive visibility by naming observed endpoints, filesystem artifacts, and campaign infrastructure, but these details should be treated as campaign-linked detections rather than universal signatures of every exploitation attempt.

Source	Contribution	Confidence
Oracle Security Alert / verbose advisory	Canonical affected versions, attack surface, CVSS, and takeover impact statement	High
CVE Program API	Canonical CVE record, vendor, product, and affected version confirmation	High
NVD API	Normalized metadata, CPEs, KEV metadata, and CWE-306 mapping	High
CISA KEV entry	Confirmed active exploitation, due date, and urgency language	High
Mandiant / GTIG blog	Detailed campaign context, targeted endpoints, post-exploitation artifacts, and immediate hunting guidance	Medium-High
Rapid7 blog	Secondary synthesis, urgency framing, and note that public research characterized the flaw as SSRF-to-RCE	Medium

Analyst confidence: High that the vulnerability is actively exploited and demands emergency remediation. Medium confidence on the exact exploitation chain mechanics because the most detailed public narratives are secondary and campaign-specific rather than vendor-authored root-cause writeups.

4. Key Findings

Field	Value
CVE	CVE-2026-35273

Vendor	Oracle
Product	PeopleSoft Enterprise PeopleTools
Component	Updates Environment Management
Affected versions	8.61, 8.62
Reachability	Unauthenticated network access via HTTP
Impact	Takeover of PeopleSoft Enterprise PeopleTools / remote code execution-class compromise
CVSS v3.1	9.8 Critical
CVSS vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
KEV date added	2026-06-12
KEV due date (FCEB)	2026-06-15
KEV ransomware-campaign-use field	Known
Primary weakness taxonomy	CWE-306 Missing Authentication for Critical Function

Key analytical findings:

- Oracle and NVD describe the vulnerable path as reachable without authentication over HTTP, which means exposure management is central to risk reduction.
- CISA KEV inclusion and Mandiant's observed exploitation window indicate defenders should assume opportunistic scanning and weaponization are already underway.
- Public threat reporting specifically associates exploitation with Environment Management Hub (PSEMHUB) endpoints and follow-on activity under PeopleSoft web-tier directories.
- The lack of a publicly enumerated patch version in open Oracle sources means patch verification must rely on internal Oracle support documentation and local change-management evidence rather than public release notes alone.

Attack Scenario	Practical Defender Interpretation
Internet-facing PSEMHUB exposure	Highest-likelihood initial access path; treat as emergency remediation and hunt priority
Broadly reachable internal PeopleSoft tier	Adversaries with an initial foothold may exploit east-west access paths if segmentation is weak
Delayed patching with temporary perimeter controls only	Exposure may shrink, but compromise risk remains if attackers already reached the host prior to isolation
Multi-server PeopleSoft estate with weak asset inventory	High chance of missed vulnerable instances and inconsistent remediation coverage

5. Threat Context

Mandiant / GTIG reported active compromise and extortion activity attributed to UNC6240 (ShinyHunters) between 2026-05-27 and 2026-06-09, predating Oracle's 2026-06-10 advisory and therefore constituting zero-day exploitation. GTIG stated it notified more than 100 organizations with potentially exposed endpoints, with a heavy concentration in the higher education sector. This matters because it shows the exploitation campaign was not theoretical or isolated; adversaries were systematically identifying and abusing exposed PeopleSoft infrastructure before public remediation guidance was available.

The same reporting ties exploitation to Environment Management Hub (PSEMHUB) exposure and describes observed attacker staging infrastructure that hosted MeshCentral agents and lateral-movement tooling. GTIG highlighted five sequential staging IPs (142.11.200.186 through 142.11.200.190), Python SimpleHTTP servers on port 8888, a hardcoded C2 endpoint at `wss://azurenetafiles.net:443/agent.ashx`, and suspicious web-tier artifacts such as non-shipped `.jsp` files or unexpected `logs`, `persistantstorage`, and `scratchpad` directories under PSEMHUB paths. These are valuable hunting leads, but they should be treated as campaign-linked indicators rather than the only valid evidence of exploitation.

Public reporting is not fully consistent on weakness taxonomy. Oracle, the CVE Program, and NVD frame the issue as an unauthenticated compromise path and NVD currently maps it to CWE-306. Rapid7 notes that TrendAI publicly characterized the underlying flaw as SSRF-to-RCE and associated it with CWE-918. Lost Boys Cyber assesses that defenders should not wait for perfect root-cause consensus before acting: the operationally relevant facts are that the flaw is remotely reachable, unauthenticated, high-impact, and actively exploited.

5.1 MITRE ATT&CK Mapping

Technique	Name	Evidence / Rationale
T1190	Exploit Public-Facing Application	Best fit for exploitation of internet-facing PeopleSoft / PSEMHUB endpoints.
T1505.003	Server Software Component: Web Shell	GTIG advised checking for unexpected `.jsp` files under `PSEMHUB.war`, consistent with web-shell style persistence.
T1105	Ingress Tool Transfer	Reported staging and deployment of MeshCentral agents and related tooling after initial compromise.
T1021.002	SMB/Windows Admin Shares	GTIG recommended monitoring outbound SMB traffic from PeopleSoft hosts to untrusted destinations during compromise assessment.
T1071.001	Application Layer Protocol: Web Protocols	Reported C2 over WebSocket / HTTPS-like web traffic to `azurenetafiles.net`.

6. Detection and Hunting

Detection should focus on both exploitation attempts and post-compromise behaviors because vendor-public exploit details remain limited. The strongest public hunting anchors are suspicious POST requests to PeopleSoft endpoints, unexpected filesystem artifacts beneath PSEMHUB paths, outbound connections from PeopleSoft hosts to attacker infrastructure or unusual external SMB destinations, and deployment of remote-management tooling inconsistent with the environment's baseline.

Signal	Telemetry Source	Analytic Goal
External POST requests to `PSEMHUB/hub` or `PSIGW/HttpListeningConnector`	WebLogic / PIA access logs, reverse proxy logs, WAF logs	Identify exploitation attempts and exposure from untrusted sources
New `.jsp` files under `PSEMHUB.war`	EDR file telemetry, FIM, server filesystem audits	Detect likely web-shell or persistence deployment
New `logs`, `persistantstorage`, `scratchpad`, or unexpected transaction paths under PSEMHUB	EDR file telemetry, FIM	Detect attacker staging or dropped tooling
Outbound connections from PeopleSoft	EDR network telemetry, firewall, NetFlow	Detect post-exploitation C2 or lateral

hosts to `azurenetfiles.net`, sequential staging IPs, or external SMB		movement
Execution or presence of MeshCentral-style agent filenames	EDR process and file telemetry	Identify follow-on remote-management persistence

6.1 Sigma Starting Point

```

title: Oracle PeopleSoft PSEMHUB Exploitation Attempt or Follow-On Artifact
id: 6d6e95f1-0bf0-4c68-8a6a-cve202635273
status: experimental
description: Detects suspicious Oracle PeopleSoft PSEMHUB exploitation indicators from public reporting on CVE-2026-35273.
references:
  - https://www.oracle.com/security-alerts/alert-cve-2026-35273.html
  - https://cloud.google.com/blog/topics/threat-intelligence/shinyhunters-targets-education-sector-oracle-exploit
logsource:
  product: linux
  category: webserver
definition: Adapt to WebLogic, reverse proxy, or WAF telemetry that captures HTTP URI and method.
detection:
  selection_uri:
    cs-method: POST
    cs-uri-stem|contains:
      - /PSEMHUB/hub
      - /PSIGW/HttpListeningConnector
  filter_internal:
    c-ip|cidr:
      - 10.0.0.0/8
      - 172.16.0.0/12
      - 192.168.0.0/16
    condition: selection_uri and not filter_internal
falsepositives:
  - Legitimate internal administration or integration traffic to PSEMHUB and PSIGW connectors
level: high

```

6.2 KQL Hunt for Filesystem and Network Artifacts

```

let lookback = 30d;
let suspiciousPaths = dynamic([
  "/PSEMHUB.war/",
  "/envmetadata/transactions/",
  "/scratchpad/",
  "/persistantstorage/"
]);
DeviceFileEvents
| where Timestamp > ago(lookback)
| where FolderPath has_any (suspiciousPaths) or FileName endswith ".jsp"
| project Timestamp, DeviceName, ActionType, FolderPath, FileName, InitiatingProcessFileName, InitiatingProcessCommandLine
| union (
  DeviceNetworkEvents
  | where Timestamp > ago(lookback)
  | where RemoteUrl has "azurenetfiles.net"
    or RemoteIP in
      ("142.11.200.186", "142.11.200.187", "142.11.200.188", "142.11.200.189", "142.11.200.190")
    or RemotePort in (445, 8888)
  | project Timestamp, DeviceName, ActionType, RemoteUrl, RemoteIP, RemotePort, InitiatingProcessFileName, InitiatingProcessCommandLine
)
| order by Timestamp desc

```

6.3 KQL Hunt for External POST Activity via Web / Proxy Logs

```
CommonSecurityLog
```

```

| where TimeGenerated > ago(30d)
| where RequestMethod =~ "POST"
| where RequestURL has "/PSEMHUB/hub" or RequestURL has "/PSIGW/HttpListeningConnector"
| extend SrcIp = coalesce(SourceIP, SourceHostName), Dst = coalesce(DestinationHostName, DestinationIP)
| project TimeGenerated, DeviceVendor, DeviceProduct, SrcIp, Dst, RequestURL, RequestMethod, Activity
| order by TimeGenerated desc

```

Hunt hypotheses:

- Vulnerable PeopleSoft systems received suspicious POST requests to PSEMHUB or PSIGW connector endpoints from external or unusual internal source IPs.
- Successful exploitation led to new JSPs or attacker-created directories under PSEMHUB web-tier paths.
- Compromised hosts initiated outbound web or SMB communications that do not fit the normal PeopleSoft application profile.
- Affected environments may show remote-management tooling or lateral-movement behavior shortly after suspicious web requests.

Hunt Question	Evidence to Review
Which PeopleSoft hosts saw external POSTs to the named endpoints?	Access logs, WAF, reverse proxy, firewall session logs
Were any new JSP files or suspicious directories created?	FIM, EDR file timeline, backup diff, server shell history
Did a PeopleSoft server contact attacker infrastructure or external SMB?	NetFlow, firewall logs, EDR network events
Was remote-management tooling dropped after web access?	EDR process/file events, package inventory, scheduled task / service creation

7. Recommendations

Priority	Owner	Action
Critical	Application / ERP owners	Apply Oracle's out-of-band remediation for CVE-2026-35273 to every affected PeopleTools 8.61 and 8.62 deployment and validate the resulting patch level through Oracle support documentation and local change records.
Critical	Infrastructure / application owners	Disable the Environment Management Hub service in multi-server deployments or remove / isolate PSEMHUB in single-server deployments where feasible, in line with Oracle and GTIG guidance.
Critical	Network / security engineering	Block external access to `/PSEMHUB/*` and `/PSIGW/HttpListeningConnector` immediately if business constraints prevent same-day remediation.
High	SOC / IR	Review historical logs for POST requests to the named endpoints, unexpected `.jsp` files, suspicious PSEMHUB directory creation, outbound SMB, and connections to `azurenetfiles.net` or related infrastructure.
High	SOC / detection engineering	Deploy detections for exploitation attempts

		and post-exploitation artifacts rather than relying on a single static IOC.
High	Asset / platform management	Build a complete inventory of PeopleSoft / PeopleTools instances, including test, DR, and departmental deployments that may sit outside the main ERP ownership chain.
High	IAM / application owners	Rotate sensitive credentials and review privileged integrations if compromise indicators are found, especially where PeopleSoft connects to identity stores, databases, or downstream financial / HR systems.

Recommended response timeline:

- 0 to 24 hours: identify exposed instances, restrict PSEMHUB / PSIGW exposure, apply Oracle remediation where operationally possible, and preserve logs.
- 24 to 72 hours: complete retrospective hunting, validate no missed vulnerable systems remain, and investigate any signs of web-shell, remote-management, or outbound SMB activity.
- 72 hours and beyond: verify longer-term segmentation, logging, and asset-governance controls around PeopleSoft estates to prevent repeat exposure.

8. References

- Oracle Security Alert Advisory - CVE-2026-35273
- <https://www.oracle.com/security-alerts/alert-cve-2026-35273.html>
- Oracle Text Form of Security Alert - CVE-2026-35273 Risk Matrices
- <https://www.oracle.com/security-alerts/cve-2026-35273verbose.html>
- CVE Program record for CVE-2026-35273
- <https://cveawg.mitre.org/api/cve/CVE-2026-35273>
- NVD API record for CVE-2026-35273
- <https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2026-35273>
- CISA Known Exploited Vulnerabilities Catalog entry for CVE-2026-35273
- https://www.cisa.gov/known-exploited-vulnerabilities-catalog?field_cve=CVE-2026-35273
- Google Cloud / Mandiant: ShinyHunters Targets Education Sector with Oracle PeopleSoft Exploit
- <https://cloud.google.com/blog/topics/threat-intelligence/shinyhunters-targets-education-sector-oracle-exploit>
- Rapid7: Active Exploitation of Oracle PeopleSoft Zero-Day (CVE-2026-35273)
- <https://www.rapid7.com/blog/post/etr-active-exploitation-of-oracle-peoplesoft-zero-day-cve-2026-35273/>